RESTful API Specification · 2/2569

Northwind BMS API Documentation

เอกสารข้อกำหนดและการเรียกใช้งาน RESTful Web Application Programming Interface

หัวข้อโครงงาน: ระบบบริหารจัดการธุรกิจ Northwind BMS (Northwind Business Management System)
สถาปัตยกรรม: Bootstrap 5 + Pure PHP API Architecture + PDO OOP Class + JWT Authentication

วิชา **การพัฒนา Web Application**	ภาคการศึกษา **2/2569 (100 คะแนนเต็ม)**
สาขาวิชา **วิศวกรรมคอมพิวเตอร์ (CPE PSRU)**	ความปลอดภัย **JWT Auth & PDO Bind Parameter 100%**

1. ภาพรวมและมาตรฐานการเชื่อมต่อ (API Standard Overview)

ระบบ Northwind BMS ได้รับการออกแบบตามสถาปัตยกรรม **Decoupled RESTful API Architecture** ซึ่งแยกส่วนหน้าบ้าน (Front-End) และหลังบ้าน (Back-End) ออกจากกันอย่างชัดเจน โดยสื่อสารผ่านโปรโตคอล HTTP/HTTPS ด้วยรูปแบบข้อมูล JSON มาตรฐาน

1.1 ข้อมูลการเชื่อมต่อหลัก

คุณลักษณะ	รายละเอียด
Base URL	`/api` (เช่น `https://your-domain.com/api` หรือ `http://localhost/Web%20App/api`)
Format	`application/json; charset=utf-8` สำหรับทั้ง Request Body และ Response
Authentication	JSON Web Token (JWT) ส่งผ่าน Header: `Authorization: Bearer {token}`
SQL Security	เขียนด้วย **PDO Prepared Statement และ Bind Parameter ทุก Query** ป้องกัน SQL Injection
HTTP Methods	`GET` (อ่าน), `POST` (สร้าง), `PUT` (แก้ไข), `DELETE` (ลบ), `OPTIONS` (Preflight)

1.2 โครงสร้าง Response มาตรฐาน (Unified Response Schema)

ตัวอย่าง: การตอบกลับกรณีสำเร็จ (HTTP 200 / 201) `200 OK`

```
{
  "success": true,
  "message": "ดึงข้อมูลสินค้าสำเร็จ",
  "data": [ ... ]
}
```

ตัวอย่าง: การตอบกลับกรณีข้อมูลไม่ผ่านการตรวจสอบ (HTTP 422) `422 Unprocessable Entity`

```
{
  "success": false,
  "message": "ข้อมูลไม่ผ่านการตรวจสอบความถูกต้อง",
  "errors": [
    "กรุณากรอกชื่อสินค้า",
    "ราคาสินค้าต้องไม่ต่ำกว่า 0 บาท"
  ]
}
```

2. ระบบยืนยันตัวตน (Authentication API)

ระบบยืนยันตัวตนด้วย Pure PHP JSON Web Token (RFC 7519) ใช้งานร่วมกับตาราง `tb_users` ในฐานข้อมูล Northwind

POST `/api/auth/login` — ตรวจสอบผู้ใช้และออก JWT Token

ตรวจสอบชื่อผู้ใช้และรหัสผ่านจากตาราง `tb_users` หากถูกต้องจะออก Token อายุ 24 ชั่วโมง

Request Body (JSON) — Required

ฟิลด์	ชนิดข้อมูล	สถานะ	คำอธิบาย
username	string	จำเป็น	ชื่อผู้ใช้ เช่น admin, mango
password	string	จำเป็น	รหัสผ่านของผู้ใช้ เช่น admin1234

ตัวอย่าง Request

```
{
  "username": "admin",
  "password": "admin1234"
}
```

Response 200 OK — 200 OK

```
{
  "success": true,
  "message": "เข้าสู่ระบบสำเร็จ",
  "data": {
    "token": "eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJzdWIiOjEsInVzZXJuYW1lIjoiYWRtaW4iLCJyb2xl
    "user": {
      "id": 1,
      "username": "admin",
      "role": "Administrator",
      "name": "วชิรา ล. (Admin)"
    }
  }
}
```

GET `/api/auth/me` — ตรวจสอบสิทธิ์และสถานะของ Token

Headers: `Authorization: Bearer {token}`

Response 200 OK — 200 OK


```
{
  "success": true,
  "message": "Token ถูกต้อง",
  "data": {
    "id": 1,
    "username": "admin",
    "role": "Administrator",
    "name": "วชิรา ล. (Admin)"
  }
}
```

3. แดชบอร์ดภาพรวม (Dashboard Overview API)

ให้บริการข้อมูลสถิติภาพรวมธุรกิจตาม **หน้าจอที่ 02 (แดชบอร์ด)**

GET `/api/dashboard` — ดึงข้อมูลสรุป 4 KPI, กราฟยอดขาย และคำสั่งซื้อล่าสุด

Headers: `Authorization: Bearer {token}`

Response 200 OK — `200 OK`


```
{
  "success": true,
  "message": "ดึงข้อมูลแดชบอร์ดสำเร็จ",
  "data": {
    "kpis": {
      "totalOrders": 196,
      "totalProducts": 79,
      "totalCustomers": 91,
      "totalSuppliers": 29
    },
    "categories": [
      { "id": 1, "name": "Beverages", "productCount": 12 },
      { "id": 2, "name": "Condiments", "productCount": 13 }
    ],
    "recentOrders": [
      {
        "id": 10443,
        "orderDate": "12/2/1997",
        "customerName": "Ernst Handel",
        "employeeName": "Anne Dodsworth",
        "shipperName": "Federal Shipping",
        "itemCount": 2
      }
    ],
    "monthlyOrders": [
      { "month": "เม.ย.", "count": 12 },
      { "month": "พ.ค.", "count": 18 },
      { "month": "พ.ย.", "count": 31 }
    ]
  }
}
```

4. การจัดการสินค้า (Products API — หน้าจอ 03 & 04)

รองรับการทำ CRUD เต็มรูปแบบกับตาราง `tb_products` พร้อมการเชื่อมโยงหมวดหมู่และผู้จัดจำหน่าย

GET `/api/products` — ดึงรายการสินค้าทั้งหมด + ค้นหา + ตัวกรอง

Query Parameters

PARAMETER	TYPE	สถานะ	คำอธิบาย
search	string	ไม่บังคับ	ค้นหาจากชื่อสินค้า, หมวดหมู่ หรือผู้จัดจำหน่าย
category_id	integer	ไม่บังคับ	กรองตามรหัสหมวดหมู่สินค้า
supplier_id	integer	ไม่บังคับ	กรองตามรหัสผู้จัดจำหน่าย

Response 200 OK — `200 OK`


```
{
  "success": true,
  "message": "ดึงข้อมูลสินค้าสำเร็จ",
  "total": 79,
  "data": [
    {
      "id": 1,
      "productName": "Chai",
      "supplierId": 1,
      "categoryId": 1,
      "unit": "10 boxes x 20 bags",
      "price": 18.00,
      "categoryName": "Beverages",
      "supplierName": "Exotic Liquid",
      "status": "ใช้งานอยู่"
    },
    {
      "id": 102,
      "productName": "NIKE รองเท้า",
      "supplierId": 2,
      "categoryId": 9,
      "unit": "box",
      "price": 25000.00,
      "categoryName": "Sports",
      "supplierName": "New Orleans",
      "status": "ตรวจสอบ"
    }
  ]
}
```

POST /api/products

เพิ่มข้อมูลสินค้าใหม่

Request Body (JSON) — Required

ฟิลด์	TYPE	ข้อจำกัด (VALIDATION RULES)
productName	string	ห้ามว่าง, ความยาวไม่เกิน 50 ตัวอักษร
categoryId	integer	ต้องเป็นรหัสหมวดหมู่ที่มีอยู่จริงในระบบ
supplierId	integer	ต้องเป็นรหัสผู้จัดจำหน่ายที่มีอยู่จริง
unit	string	ห้ามว่าง, ความยาวไม่เกิน 30 ตัวอักษร
price	number	ต้องเป็นตัวเลข และต้องไม่ต่ำกว่า 0 บาท

ตัวอย่าง Request

```
{
  "productName": "ชาเขียวมัทฉะแท้",
  "categoryId": 1,
  "supplierId": 1,
  "unit": "10 ซอง x 50 กรัม",
  "price": 85.50
}
```

Response 201 Created — 201 Created

```
{
  "success": true,
  "message": "เพิ่มข้อมูลสินค้าเรียบร้อยแล้ว",
  "data": { "id": 108 }
}
```

PUT /api/products/{id}

แก้ไขข้อมูลสินค้า

รับ JSON Body โครงสร้างเดียวกับ POST /api/products เพื่อปรับปรุงข้อมูลตามรหัส ID

Response 200 OK — 200 OK

```
{
  "success": true,
  "message": "แก้ไขข้อมูลสินค้าเรียบร้อยแล้ว",
  "data": { "id": 108 }
}
```

DELETE `/api/products/{id}` ลบข้อมูลสินค้าออกจากระบบ

Response 200 OK `200 OK`

```
{
  "success": true,
  "message": "ลบสินค้าเรียบร้อยแล้ว",
  "data": null
}
```

5. คำสั่งซื้อและรายละเอียด (Orders & Details API — หน้าจอ 06 & 07)

จัดการความสัมพันธ์ระหว่างคำสั่งซื้อ (tb_orders) และรายการสินค้าในออร์เดอร์ (tb_orderdetails)

GET `/api/orders` — ดึงรายการคำสั่งซื้อทั้งหมด + ค้นหา + กรองสถานะ

Query Parameters: search, status (จัดส่งแล้ว / กำลังดำเนินการ / ยกเลิก), shipper_id

Response 200 OK — 200 OK


```
{
  "success": true,
  "message": "ดึงรายการคำสั่งซื้อสำเร็จ",
  "total": 196,
  "data": [
    {
      "id": 10443,
      "orderDate": "12/2/1997",
      "customerId": 66,
      "customerName": "Reggiani Caseifici",
      "employeeId": 8,
      "employeeName": "Laura Callahan",
      "shipperId": 1,
      "shipperName": "Speedy Express",
      "itemCount": 2,
      "totalAmount": 1008.00,
      "status": "จัดส่งแล้ว"
    }
  ]
}
```

GET `/api/orders/{id}` ดึงรายละเอียดคำสั่งซื้อและรายการสินค้าครบชุด

Response 200 OK

200 OK


```
{
  "success": true,
  "data": {
    "id": 10443,
    "orderDate": "12/2/1997",
    "customerName": "Reggiani Caseifici",
    "customerContact": "Maurizio Moroni",
    "customerAddress": "Strada Provinciale 124",
    "customerCity": "Reggio Emilia",
    "customerCountry": "Italy",
    "employeeName": "Laura Callahan",
    "shipperName": "Speedy Express",
    "shipperPhone": "(503) 555-9831",
    "status": "จัดส่งแล้ว",
    "totalAmount": 1008.00,
    "totalUnits": 18,
    "itemCount": 2,
    "items": [
      {
        "orderDetailId": 517,
        "productId": 11,
        "productName": "Queso Cabrales",
        "unit": "1 kg pkg.",
        "price": 21.00,
        "quantity": 6,
        "itemTotal": 126.00
      },
      {
        "orderDetailId": 518,
        "productId": 28,
        "productName": "Rössle Sauerkraut",
        "unit": "25 - 825 g cans",
        "price": 45.60,
        "quantity": 12,
        "itemTotal": 547.20
      }
    ]
  }
}
```

POST `/api/orders` — สร้างคำสั่งซื้อใหม่พร้อมบันทึกรายการสินค้า

ตัวอย่าง Request

```
{
  "customerId": 20,
  "employeeId": 1,
  "shipperId": 2,
  "orderDate": "1/11/2026",
  "items": [
    { "productId": 1, "quantity": 12 },
    { "productId": 2, "quantity": 8 }
  ]
}
```

Response 201 Created — `201 Created`

```
{
  "success": true,
  "message": "สร้างคำสั่งซื้อใหม่เรียบร้อยแล้ว",
  "data": { "id": 10444 }
}
```

6. โมดูลข้อมูลหลัก (Master Data APIs — 5 ตารางหลัก)

6.1 หมวดหมู่สินค้า (Categories — `tb_categories`)

METHOD & ENDPOINT	หน้าที่การทำงาน	ตัวอย่างพารามิเตอร์
`GET /api/categories`	ดึงหมวดหมู่ทั้งหมดพร้อมจำนวนสินค้า (productCount)	-
`GET /api/categories/{id}`	ดึงข้อมูลหมวดหมู่รายตัวตาม ID	`id`: 1
`POST /api/categories`	เพิ่มหมวดหมู่ใหม่	`{"name": "เครื่องดื่ม", "description": "น้ำผลไม้ ชา กาแฟ"}`
`PUT /api/categories/{id}`	แก้ไขข้อมูลหมวดหมู่	`{"name": "เครื่องดื่ม", "description": "..."}`
`DELETE /api/categories/{id}`	ลบหมวดหมู่สินค้า	`id`: 10

6.2 ลูกค้า (Customers — `tb_customers`)

METHOD & ENDPOINT	หน้าที่การทำงาน	ตัวอย่างพารามิเตอร์
`GET /api/customers`	ดึงทะเบียนลูกค้าทั้งหมด (รองรับ `?search=`, `?country=`)	`?country=Germany`
`GET /api/customers/countries`	ดึงรายชื่อประเทศทั้งหมด 21 ประเทศ สำหรับใส่ Dropdown	-
`POST /api/customers`	เพิ่มลูกค้าใหม่	`{"name": "...", "contactName": "...", "city": "...", "country": "..."}`
`PUT /api/customers/{id}`	แก้ไขข้อมูลลูกค้า	JSON โครงสร้างลูกค้า
`DELETE /api/customers/{id}`	ลบข้อมูลลูกค้า	`id`: 92

6.3 ผู้จัดจำหน่าย (Suppliers — `tb_suppliers`)

METHOD & ENDPOINT	หน้าที่การทำงาน	ตัวอย่างพารามิเตอร์
`GET /api/suppliers`	ดึงผู้จัดจำหน่าย 29 ราย พร้อมจำนวนสินค้าที่จัดจำหน่าย	`?search=Exotic`
`POST /api/suppliers`	เพิ่มผู้จัดจำหน่ายใหม่	`{"name": "...", "contactName": "...", "phone": "..."}`

`PUT /api/suppliers/{id}`	แก้ไขผู้จัดจำหน่าย	JSON โครงสร้างผู้จัดจำหน่าย
`DELETE /api/suppliers/{id}`	ลบผู้จัดจำหน่าย	`id`: 30

6.4 พนักงาน (Employees — `tb_employees`)

METHOD & ENDPOINT	หน้าที่การทำงาน	ตัวอย่างพารามิเตอร์
`GET /api/employees`	ดึงรายชื่อพนักงาน พร้อม Title ตำแหน่งและ Initials	-
`POST /api/employees`	เพิ่มพนักงานใหม่	`{"firstName": "Nancy", "lastName": "Davolio", "birthDate": "..."}`
`PUT /api/employees/{id}`	แก้ไขข้อมูลพนักงาน	JSON ข้อมูลพนักงาน
`DELETE /api/employees/{id}`	ลบข้อมูลพนักงาน	`id`: 11

6.5 บริษัทขนส่ง (Shippers — `tb_shippers`)

METHOD & ENDPOINT	หน้าที่การทำงาน	ตัวอย่างพารามิเตอร์
`GET /api/shippers`	ดึงบริษัทขนส่งพร้อมสถิติจำนวนครั้งที่จัดส่ง (shipmentCount)	-
`POST /api/shippers`	เพิ่มบริษัทขนส่งใหม่	`{"name": "Flash Express", "phone": "(503) 555-0199"}`
`PUT /api/shippers/{id}`	แก้ไขข้อมูลบริษัทขนส่ง	`{"name": "...", "phone": "..."}`
`DELETE /api/shippers/{id}`	ลบบริษัทขนส่ง	`id`: 4

7. รายงานและวิเคราะห์ข้อมูล (Reports & Analytics API — หน้าจอ 12)

GET `/api/reports/summary` — ดึงข้อมูลวิเคราะห์ ยอดขายรวม สินค้าขายดี ลูกค้าชั้นนำ

Headers: `Authorization: Bearer {token}`

Response 200 OK — 200 OK


```
{
  "success": true,
  "message": "ดึงข้อมูลรายงานสำเร็จ",
  "data": {
    "kpis": {
      "totalRevenue": 2450000.00,
      "totalOrders": 196,
      "avgPerOrder": 12500.00,
      "topShipper": "United Package",
      "topShipperCount": 74
    },
    "monthlyTrends": [
      { "month": "เม.ย.", "revenue": 125000, "orders": 12 },
      { "month": "พ.ค.", "revenue": 180000, "orders": 18 },
      { "month": "พ.ย.", "revenue": 450000, "orders": 31 }
    ],
    "topProducts": [
      {
        "id": 1,
        "name": "Chai",
        "categoryName": "Beverages",
        "totalSold": 324,
        "totalSales": 5832.00
      }
    ],
    "topCustomers": [
      {
        "id": 20,
        "name": "Ernst Handel",
        "country": "Austria",
        "orderCount": 10,
        "totalSpent": 113292.00
      }
    ]
  }
}
```

8. ตารางรหัสสถานะ HTTP (HTTP Status Codes Reference)

HTTP CODE	STATUS	ความหมายและการใช้งานในระบบ
200	**OK**	การร้องขอสำเร็จ (เช่น ดึงข้อมูลสำเร็จ, แก้ไขสำเร็จ, ลบสำเร็จ)
201	**Created**	สร้างข้อมูลใหม่ในฐานข้อมูลสำเร็จ (POST /products, POST /orders)
400	**Bad Request**	คำขอไม่ถูกต้อง เช่น ไม่ส่ง JSON Body หรือข้อมูลผิดรูปแบบ
401	**Unauthorized**	ไม่พบ Token หรือ Token หมดอายุ / ชื่อผู้ใช้หรือรหัสผ่านผิด
403	**Forbidden**	ไม่มีสิทธิ์ในการเข้าถึงทรัพยากรนั้น (เช่น เข้า setup_database โดยไม่มีคีย์)
404	**Not Found**	ไม่พบ Endpoint หรือไม่พบ Record ที่ระบุด้วย ID
422	**Unprocessable Entity**	ข้อมูลไม่ผ่านการตรวจสอบความถูกต้อง (Validation Error)
500	**Internal Server Error**	เกิดข้อผิดพลาดในการประมวลผลคำสั่งหรือเชื่อมต่อฐานข้อมูลล้มเหลว

สรุปการปฏิบัติตามเกณฑ์โครงงาน:
เอกสารนี้จัดทำขึ้นตรงตามข้อกำหนดที่ 4 ของวิชาการพัฒนา Web Application โดยครอบคลุม Endpoint ทั้งหมด 30+ ตัว, ระบุ URL, Method, Header, Parameters, Response JSON และตัวอย่างข้อมูลจริงครบถ้วนสมบูรณ์